

An **HttpOnly** cookie can be **created and read strictly by the web server**.  DEV Community

Key Characteristics

- **Creation:** It is created by the backend application server, which sends it to the web browser via the `Set-Cookie` HTTP response header containing the `HttpOnly` flag.  Medium · Tom Davidson +1
- **Reading:** It is read exclusively by the server when the browser automatically attaches the cookie to subsequent HTTP/HTTPS requests sent to that same domain.  Hexnode +1
- **Client-Side Restrictions:** The browser strictly blocks client-side scripting languages like JavaScript from accessing it. Consequently, APIs like `document.cookie` or the Cookie Store API cannot read, create, or modify an HttpOnly cookie.  MDN Web Docs +3

Why Is It Used?

The primary purpose of the `HttpOnly` flag is to **mitigate the risk of session theft** via Cross-Site Scripting (XSS) attacks. If an attacker manages to inject a malicious script into a website, the restriction ensures they cannot steal sensitive session identifiers or authentication tokens stored in the cookie.  edureka.co +3

If you are setting up secure user sessions, you can review the official [OWASP HttpOnly Guide](#) to see framework-specific implementation steps.  owasp

If you would like to explore this further, let me know:

- Which **backend framework** (e.g., Node.js, Python, PHP) you are using to create cookies.
- If you need help configuring other security flags like **Secure** or **SameSite**.  Medium · Tom Davidson +4